Rapport TP3 —Sécurisation d'un serveur Linux

Cottereaux Noah Lille Btc.28.1

1. Configuration du pare-feu

Étape 1 : Pare-feu (Firewalld)

Activation de firewalld et vérification des zones actives.

```
[noah@srv-core ~]$ sudo systemctl enable --now firewalld
Created symlink /etc/systemd/system/dbus-org.fedoraproject.FirewallD1.service → /usr/lib/systemd/system/firewalld.servic
e.
Created symlink /etc/systemd/system/multi-user.target.wants/firewalld.service → /usr/lib/systemd/system/firewalld.servic
e.
[noah@srv-core ~]$ sudo firewall-cmd --get-active-zones
public
  interfaces: enp0s10 enp0s3 enp0s8 enp0s9 bond0 bond0.42
[noah@srv-core ~]$
```

Ajout du port 2242 dans le pare-feu et rechargement.

```
[noah@srv-core ~]$ sudo firewall-cmd --get-active-zones
public
  interfaces: enp0s10 enp0s3 enp0s8 enp0s9 bond0 bond0.42
[noah@srv-core ~]$ sudo firewall-cmd --permanent --add-port=2242/tcp
success
[noah@srv-core ~]$ sudo firewall-cmd --reload
success
[noah@srv-core ~]$ sudo firewall-cmd --list-ports
2242/tcp
```

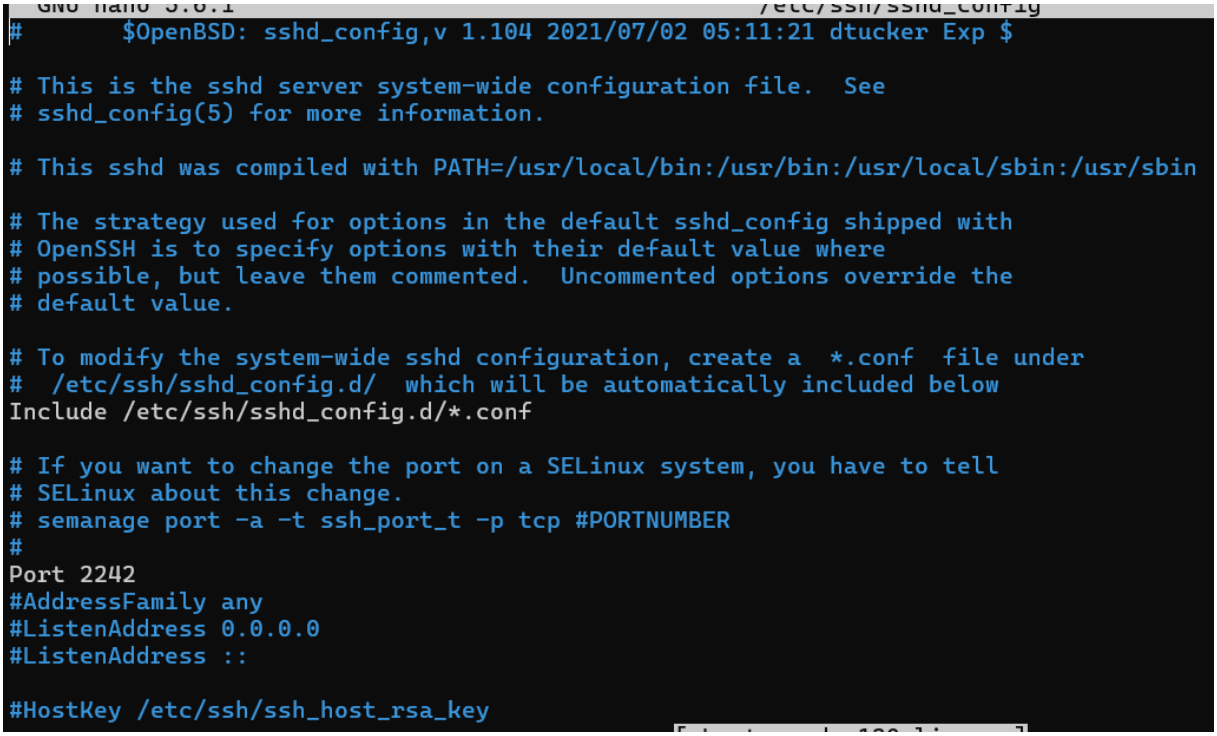
2. Durcissement et port SSH

Étape 2 : Service SSH

Commande d'ouverture du fichier sshd_config.

```
[noah@srv-core ~]$ sudo nano /etc/ssh/sshd_config
```

Vue du fichier de configuration SSH.



```
#       $OpenBSD: sshd_config,v 1.104 2021/07/02 05:11:21 dtucker Exp $

# This is the sshd server system-wide configuration file.  See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/local/bin:/usr/bin:/usr/local/sbin:/usr/sbin

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented.  Uncommented options override the
# default value.

# To modify the system-wide sshd configuration, create a  *.conf  file under
#  /etc/ssh/sshd_config.d/  which will be automatically included below
Include /etc/ssh/sshd_config.d/*.conf

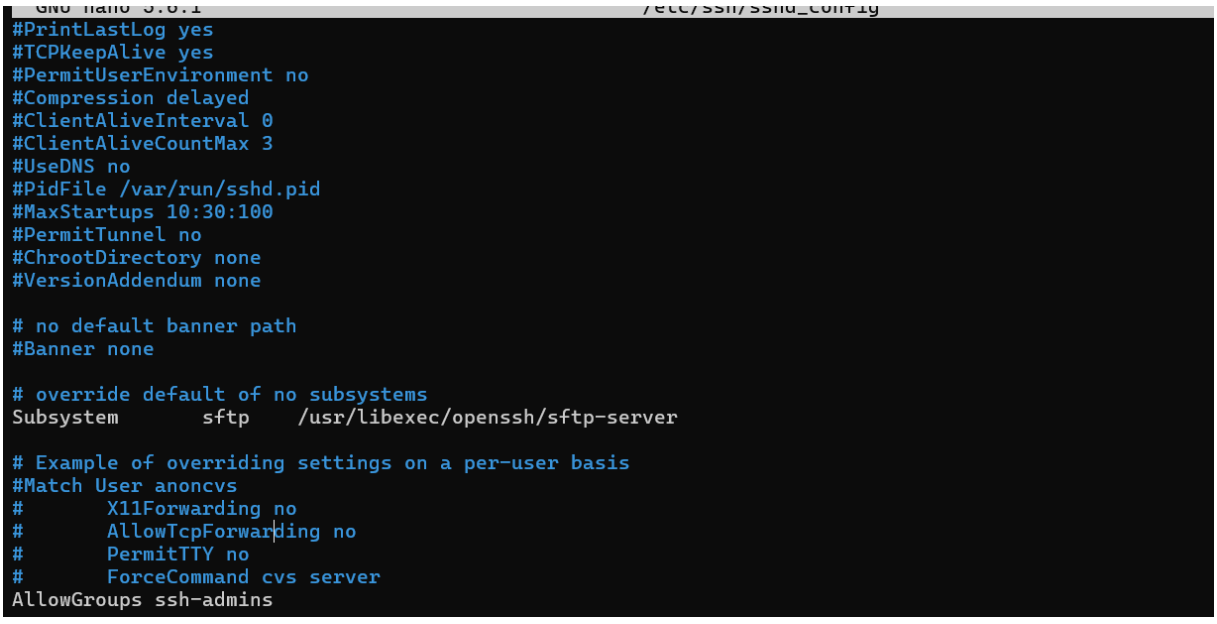
# If you want to change the port on a SELinux system, you have to tell
# SELinux about this change.
# semanage port -a -t ssh_port_t -p tcp #PORTNUMBER
#
Port 2242
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
```

Configuration de SELinux (semanage port).

```
[noah@srv-core ~]$ sudo semanage port -a -t ssh_port_t -p tcp 2242
```

Ajout de la directive AllowGroups ssh-admins.



```
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /var/run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
#Banner none

# override default of no subsystems
Subsystem       sftp    /usr/libexec/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#       X11Forwarding no
#       AllowTcpForwarding no
#       PermitTTY no
#       ForceCommand cvs server
AllowGroups ssh-admins
```

Vérification de l'écoute du port 2242 (ss -tulpn).



```
[noah@srv-core ~]$ sudo ss -tulpn | grep sshd
tcp   LISTEN 0      128          0.0.0.0:2242      0.0.0.0:*    users:(("sshd",pid=3367,fd=7))
tcp   LISTEN 0      128             [::]:2242         [::]:*    users:(("sshd",pid=3367,fd=8))
```

3. Gestion des groupes et de sudo

Étape 3 : Utilisateurs et Droits

Création du groupe ssh-admins.

```
[noah@srv-core ~]$ sudo groupadd ssh-admins
```

Redémarrage de SSH et test de la commande sudo -l.

```
[noah@srv-core ~]$ sudo systemctl restart sshd
[noah@srv-core ~]$ sudo visudo -f /etc/sudoers.d/ssh-admins
[noah@srv-core ~]$ sudo -l
Entrées Defaults correspondant pour noah sur srv-core :
    !visiblepw, always_set_home, match_group_by_gid, always_query_group_plugin, env_reset, env_keep="COLORS DISPLAY
    HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE",
    env_keep+="LC_COLLATE LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY LC_NAME LC_NUMERIC
    LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY",
    secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin

L'utilisateur noah peut utiliser les commandes suivantes sur srv-core :
    (ALL) ALL
[noah@srv-core ~]$
```

4. Durcissement du noyau Linux

Étape 4 : Noyau (Sysctl)

Création et contenu du fichier 99-security-hardening.conf.

```
  GNU nano 5.6.1                    /etc/sysctl.d/99-security-hardening.conf
# Empêcher le routage de paquets IP
net.ipv4.ip_forward = 0

# Ignorer les requêtes de broadcast ICMP (protection Smurf)
net.ipv4.icmp_echo_ignore_broadcasts = 1

# Activer la protection contre l'usurpation d'adresses (Reverse Path Filtering)
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.default.rp_filter = 1
```

Application des paramètres sysctl (sysctl --system).

```
[noah@srv-core ~]$ sudo sysctl --system
[sudo] Mot de passe de noah :
* Applying /usr/lib/sysctl.d/10-default-yama-scope.conf ...
* Applying /usr/lib/sysctl.d/50-coredump.conf ...
* Applying /usr/lib/sysctl.d/50-default.conf ...
* Applying /usr/lib/sysctl.d/50-libkcapi-optmem_max.conf ...
* Applying /usr/lib/sysctl.d/50-pid-max.conf ...
* Applying /usr/lib/sysctl.d/50-redhat.conf ...
* Applying /etc/sysctl.d/99-security-hardening.conf ...
* Applying /etc/sysctl.d/99-sysctl.conf ...
* Applying /etc/sysctl.conf ...
kernel.yama.ptrace_scope = 0
kernel.core_pattern = |/usr/lib/systemd/systemd-coredump %P %u %g %s %t %c %h %d %F
kernel.core_pipe_limit = 16
fs.suid_dumpable = 2
kernel.sysrq = 16
kernel.core_uses_pid = 1
net.ipv4.conf.default.rp_filter = 2
net.ipv4.conf.bond0/42.rp_filter = 2
net.ipv4.conf.bond0.rp_filter = 2
net.ipv4.conf.enp0s10.rp_filter = 2
net.ipv4.conf.enp0s3.rp_filter = 2
net.ipv4.conf.enp0s8.rp_filter = 2
net.ipv4.conf.enp0s9.rp_filter = 2
net.ipv4.conf.lo.rp_filter = 2
net.ipv4.conf.default.accept_source_route = 0
net.ipv4.conf.bond0/42.accept_source_route = 0
net.ipv4.conf.bond0.accept_source_route = 0
net.ipv4.conf.enp0s10.accept_source_route = 0
net.ipv4.conf.enp0s3.accept_source_route = 0
net.ipv4.conf.enp0s8.accept_source_route = 0
net.ipv4.conf.enp0s9.accept_source_route = 0
net.ipv4.conf.lo.accept_source_route = 0
net.ipv4.conf.default.promote_secondaries = 1
net.ipv4.conf.bond0/42.promote_secondaries = 1
net.ipv4.conf.bond0.promote_secondaries = 1
net.ipv4.conf.enp0s10.promote_secondaries = 1
net.ipv4.conf.enp0s3.promote_secondaries = 1
net.ipv4.conf.enp0s8.promote_secondaries = 1
net.ipv4.conf.enp0s9.promote_secondaries = 1
net.ipv4.conf.lo.promote_secondaries = 1
```

5. Configuration d'Auditd

Étape 5 : Audit et Journalisation

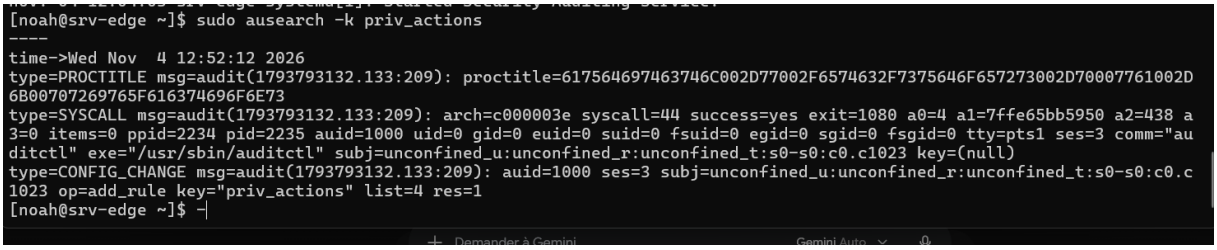
Installation d'audit et ajout de la règle sur /etc/sudoers.

```
[noah@srv-edge ~]$ sudo dnf install -y audit
sudo systemctl enable --now auditd
Rocky Linux 9 - BaseOS                                                    0.0  B/s |   0  B     00:30
Errors during downloading metadata for repository 'baseos':
  - Curl error (6): Couldn't resolve host name for https://mirrors.rockylinux.org/mirrorlist?arch=x86_64&repo=BaseOS-9 [
Could not resolve host: mirrors.rockylinux.org]
Erreur : Échec du téléchargement des métadonnées pour le dépôt « baseos » : Cannot prepare internal mirrorlist: Curl err
or (6): Couldn't resolve host name for https://mirrors.rockylinux.org/mirrorlist?arch=x86_64&repo=BaseOS-9 [Could not re
solve host: mirrors.rockylinux.org]
[noah@srv-edge ~]$ sudo auditctl -w /etc/sudoers -p wa -k priv_actions
Old style watch rules are slower
[noah@srv-edge ~]$
```

Vérification du statut du service auditd.

```
[noah@srv-core ~]$ sudo sysctl --system
* Applying /usr/lib/sysctl.d/10-default-yama-scope.conf ...
* Applying /usr/lib/sysctl.d/50-coredump.conf ...
* Applying /usr/lib/sysctl.d/50-default.conf ...
* Applying /usr/lib/sysctl.d/50-libkcapi-optmem_max.conf ...
* Applying /usr/lib/sysctl.d/50-pid-max.conf ...
* Applying /usr/lib/sysctl.d/50-redhat.conf ...
* Applying /etc/sysctl.d/99-security-hardening.conf ...
* Applying /etc/sysctl.d/99-sysctl.conf ...
* Applying /etc/sysctl.conf ...
kernel.yama.ptrace_scope = 0
kernel.core_pattern = |/usr/lib/systemd/systemd-coredump %P %u %g %s %t %c %h %d %F
kernel.core_pipe_limit = 16
fs.suid_dumpable = 2
kernel.sysrq = 16
kernel.core_uses_pid = 1
net.ipv4.conf.default.rp_filter = 2
net.ipv4.conf.bond0/42.rp_filter = 2
net.ipv4.conf.bond0.rp_filter = 2
net.ipv4.conf.enp0s10.rp_filter = 2
net.ipv4.conf.enp0s3.rp_filter = 2
net.ipv4.conf.enp0s8.rp_filter = 2
net.ipv4.conf.enp0s9.rp_filter = 2
net.ipv4.conf.lo.rp_filter = 2
net.ipv4.conf.default.accept_source_route = 0
net.ipv4.conf.bond0/42.accept_source_route = 0
net.ipv4.conf.bond0.accept_source_route = 0
```

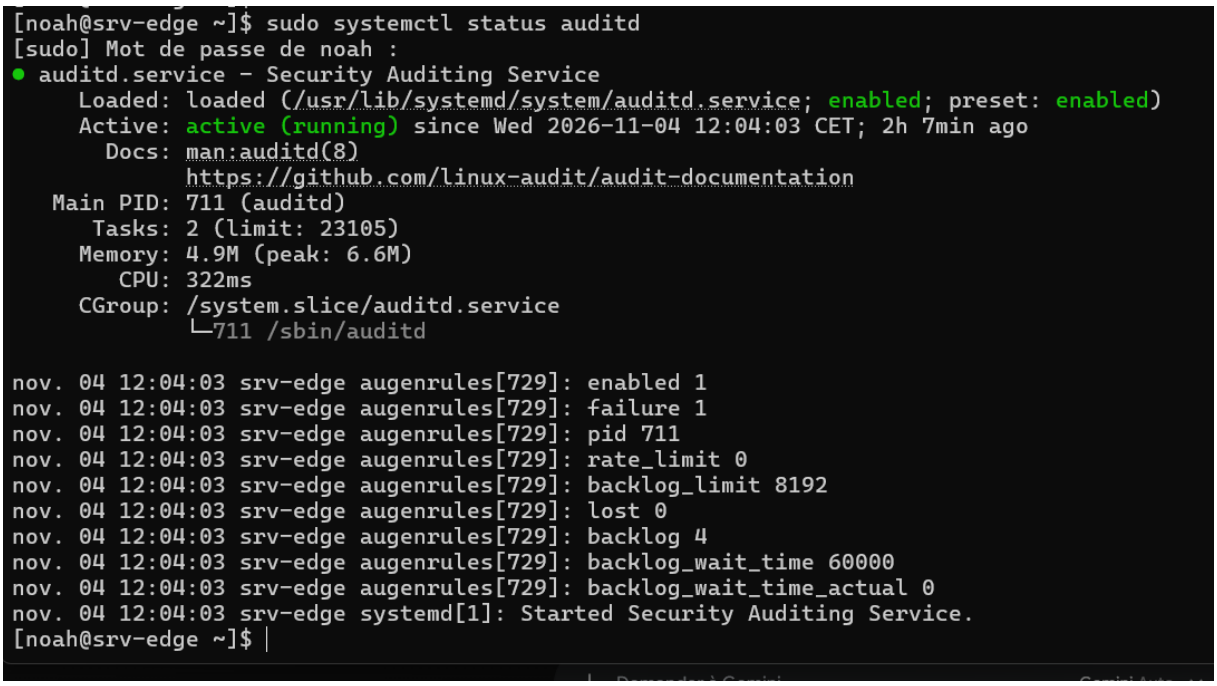
Consultation des logs d'audit avec ausearch.



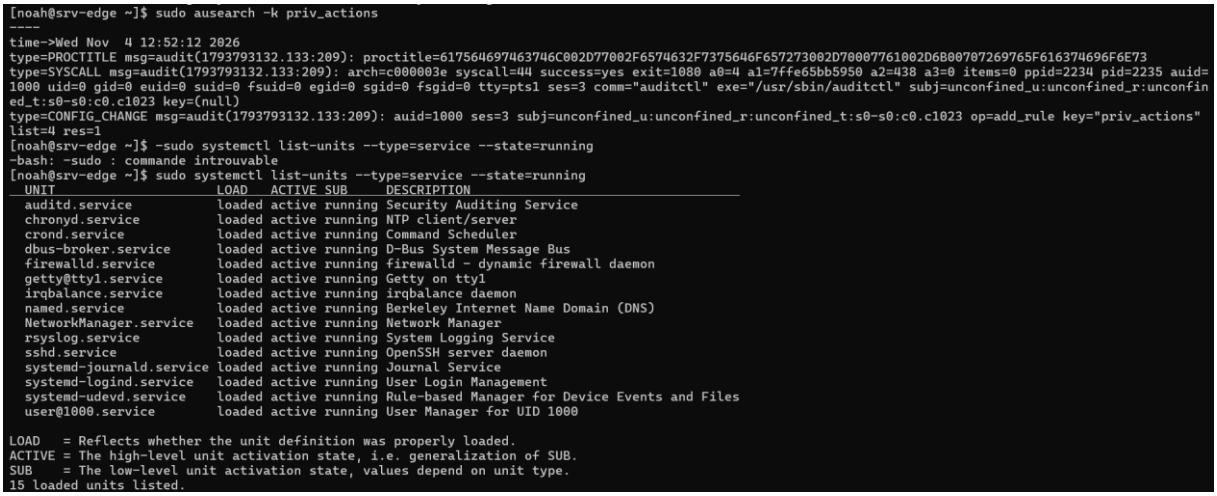
6 Tests finaux et surface d’attaque

Etape 6 : Validation final

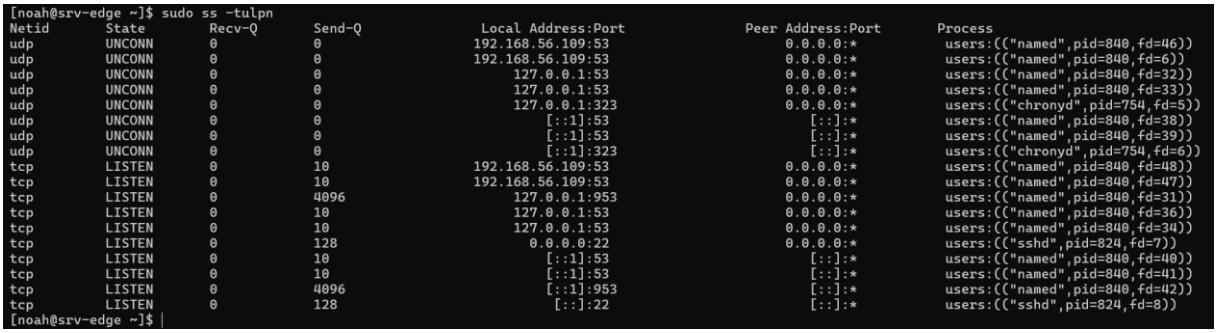
Test de connexion SSH réussi entre srv-edge et srv-core sur le port 2242.



Analyse de la surface d'attaque (systemctl list-units).



Audit final des ports réseau ouverts (ss -tulpn).



```
[noah@srv-edge ~]$ sudo ss -tulpn
Netid       State        Recv-Q       Send-Q              Local Address:Port              Peer Address:Port       Process
udp         UNCONN       0            0                192.168.56.109:53                   0.0.0.0:*           users:(("named",pid=840,fd=46))
udp         UNCONN       0            0                192.168.56.109:53                   0.0.0.0:*           users:(("named",pid=840,fd=6))
udp         UNCONN       0            0                     127.0.0.1:53                   0.0.0.0:*           users:(("named",pid=840,fd=32))
udp         UNCONN       0            0                     127.0.0.1:53                   0.0.0.0:*           users:(("named",pid=840,fd=33))
udp         UNCONN       0            0                     127.0.0.1:323                  0.0.0.0:*           users:(("chronyd",pid=754,fd=5))
udp         UNCONN       0            0                         [::1]:53                      [::]:*           users:(("named",pid=840,fd=38))
udp         UNCONN       0            0                         [::1]:53                      [::]:*           users:(("named",pid=840,fd=39))
udp         UNCONN       0            0                         [::1]:323                     [::]:*           users:(("chronyd",pid=754,fd=6))
tcp         LISTEN       0            10               192.168.56.109:53                   0.0.0.0:*           users:(("named",pid=840,fd=48))
tcp         LISTEN       0            10               192.168.56.109:53                   0.0.0.0:*           users:(("named",pid=840,fd=47))
tcp         LISTEN       0            4096                  127.0.0.1:953                  0.0.0.0:*           users:(("named",pid=840,fd=31))
tcp         LISTEN       0            10                    127.0.0.1:53                   0.0.0.0:*           users:(("named",pid=840,fd=36))
tcp         LISTEN       0            10                    127.0.0.1:53                   0.0.0.0:*           users:(("named",pid=840,fd=34))
tcp         LISTEN       0            128                     0.0.0.0:22                   0.0.0.0:*           users:(("sshd",pid=824,fd=7))
tcp         LISTEN       0            10                        [::1]:53                      [::]:*           users:(("named",pid=840,fd=40))
tcp         LISTEN       0            10                        [::1]:53                      [::]:*           users:(("named",pid=840,fd=41))
tcp         LISTEN       0            4096                      [::1]:953                     [::]:*           users:(("named",pid=840,fd=42))
tcp         LISTEN       0            128                        [::]:22                      [::]:*           users:(("sshd",pid=824,fd=8))
[noah@srv-edge ~]$
```

Conclusion du TP3

Ce TP3 dédié à la sécurisation d'infrastructures Linux (srv-edge et srv-core) a permis de mettre en pratique les principes fondamentaux du durcissement système (*hardening*) et de l'administration sécurisée.

À travers la réalisation de ce TP, les principales compétences acquises et validées sont les suivantes :

- Le cloisonnement et la restriction des accès distants : Modification du port d'écoute par défaut du service SSH au profit du port 2242 afin de limiter l'exposition aux attaques automatisées, associée à une restriction des connexions aux seuls membres du groupe dédié ssh-admins.
- Le filtrage réseau rigoureux : Maîtrise de l'outil firewalld pour autoriser uniquement les flux légitimes indispensables au bon fonctionnement de l'architecture.
- Le durcissement du noyau Linux (*sysctl*) : Implémentation de paramètres de sécurité au niveau du noyau (tels que la désactivation de l'acheminement IP et l'activation du filtrage par chemin inverse rp_filter) pour prévenir les attaques par usurpation et le routage non désiré.
- La traçabilité et l'audit de sécurité : Configuration et exploitation du service d'audit du noyau (auditd) pour surveiller en temps réel les modifications apportées aux fichiers sensibles du système, garantissant ainsi une traçabilité indispensable en environnements de production.

En conclusion, ce projet pratique a permis de consolider une démarche méthodique de sécurisation proactive, transformant des serveurs bruts en environnements robustes, cloisonnés et audités, tout en veillant à valider la non-régression des services par des tests de connectivité croisée.